PC 与移动端权限一致性

企业 AI 智能体中台 · 第 18 章 · 给技术 / 安全评审（A4）

平台无论通过 PC Web 还是手机 H5/App 访问，**权限判定只用同一套逻辑、同一份数据**，绝不因入口不同而放宽或收紧。这是避免“手机端泄密” “两端看到的不一样”等问题的根本保障。

18.1 共用同一召回过滤层

PC 与移动端都调用**同一个 RAG 召回服务**：请求携带调用者身份（userId / deptId / role），服务在**召回阶段**即按 scope / owner / dept 过滤，越权片段根本不进入大模型上下文。两端没有任何“旁路”——手机端不是只读镜像，而是同一服务的不同前端。

- 同一过滤代码：过滤逻辑只在召回服务实现一次，PC/移动共用
- 同一元数据：每条知识带 (owner_id, dept_id, scope)，两端一致
- 同一 RBAC：角色与策略在服务端校验，前端仅做展示

18.2 一致性检查清单

检查项	PC 端	移动端	判定
可见部门空间	仅所属部门	仅所属部门	应一致
可见知识范围	全域+部门+个人	全域+部门+个人	应一致
越权访问测试	不可见对方部门	不可见对方部门	应一致
审批资格	按角色	按角色	应一致
审计留痕	全量记录	全量记录	应一致
导出审批	敏感走审批	敏感走审批	应一致

18.3 风险与纠偏

- 风险：移动端为赶进度“临时放宽”过滤，或前端缓存越权内容
- 纠偏：过滤器只在服务端，前端不持有越权数据；缓存仅存脱敏摘要
- 测试：两端共用同一套越权测试用例，CI 中强制回归
- 审计：两端操作统一进入同一审计流，出现差异可追溯到具体入口

18.4 数据流对照图：PC 与移动端共用召回过滤（单一过滤点）

下图强调：PC Web 与手机 H5/App
是**同一个召回服务的两个前端**，不存在“移动端只读镜像”或“旁路”。所有权限判定集中在**唯一过滤点**（scope / owner / dept），越权片段在召回阶段即被剔除，根本不进入大模型上下文。



配套参考：第 16 章《移动端（手机）操作设计》、第 17 章《移动端 MVP 开发清单》（含接口字段级定义）。三份 A4 合并即“移动端评审包”。